Which control?

Start from the requirement, not the product. Each panel gives the question to ask, the scenario words that decide it, and the wrong answer the question is built to tempt.

SC-500 Academy posters
Front: nineteen decisions SC-500 is built around
Checked against Microsoft Learn on 20 October 2026

Managed identity vs service principal

1.1.4 1.1.6

An application needs to call an Azure service. Which identity should it use?

- *"no credentials to store or rotate, app runs on an Azure VM / App Service"* → **Managed identity**
- *"GitHub Actions or an on-premises job must authenticate without a secret"* → **Workload identity federation, on an app registration or a user-assigned managed identity**
- *"one identity shared by several resources"* → **User-assigned managed identity**

Trap. Treating a managed identity as automatically least-privilege. It removes the credential problem, not the permission problem.

PIM vs Conditional Access

1.1.1 1.1.2

Is the requirement about how long someone holds privilege, or about the conditions of a sign-in?

- *"just-in-time, eligible, time-bound, approval to activate"* → **PIM**
- *"compliant device, location, sign-in risk, block legacy authentication"* → **Conditional Access**

Trap. Answering "require MFA for admins" with PIM alone, or "remove permanent admins" with Conditional Access.

Azure RBAC vs Azure Policy

1.3.1 1.3.5 1.3.7

Is the requirement about who can act, or about what any resource is allowed to look like?

- *"only the network team may manage virtual networks"* → **Azure RBAC**
- *"no storage account may allow public blob access, even for Owners"* → **Azure Policy (Deny)**
- *"add a tag automatically / deploy diagnostic settings when missing"* → **Azure Policy (Modify / DeployIfNotExists)**

Trap. Picking a custom role to stop people creating resources in the wrong region - that is a policy (allowed locations).

Preventive vs detective controls

1.3.1 1.3.3 4.1.1 4.1.3

Must the bad thing be stopped, or seen and acted on?

- *"must not be able to create"* → **Preventive (Azure Policy Deny)**
- *"notify the SOC when it happens"* → **Detective (alert / analytics rule)**

Trap. Answering a "prevent" requirement with Audit, or with a Defender alert.

Secrets vs keys vs certificates in Key Vault

1.2.5

What kind of sensitive material is it, and does the application ever need to see it?

- *"connection string, API key, password"* → **Secret**
- *"customer-managed key, encryption at rest, the key must never leave an HSM"* → **Key**
- *"TLS certificate with automatic renewal"* → **Certificate**

Trap. Storing an encryption key as a secret so the app can "use it" - the point of a key is that it never leaves the vault.

Key Vault: Azure RBAC vs access policies

1.2.3

How should data-plane access to a vault be granted?

- *"grant an app read access to one specific secret only"* → **Azure RBAC scoped to the secret**
- *"make vault access PIM-eligible and reviewable"* → **Azure RBAC**

Trap. Assuming Key Vault Contributor cannot read secrets - under access policies it can grant itself access.

Private endpoint vs service endpoint

2.1.2 2.3.6

Must the service have a private IP address in your network, or is it enough to limit its public endpoint to your subnets?

- *"private IP, reachable from on-premises, disable public access"* → **Private endpoint**
- *"allow only these subnets through the storage firewall, no extra cost"* → **Service endpoint**

Trap. Assuming a private endpoint closes public access - you must also disable public network access, and get DNS right.

NSG vs Azure Firewall vs security admin rule

2.3.1 2.3.2 2.3.8

Where should this traffic rule live - next to the workload, centrally for inspection, or as an organisation-wide floor?

- *"allow web tier to reach database tier on 1433 only"* → **NSG with application security groups**
- *"allow outbound only to *.contoso.com, block known malicious IPs"* → **Azure Firewall**
- *"block RDP from the internet in every virtual network, even if a team adds an allow"* → **Security admin rule**

Trap. Choosing an NSG to filter outbound traffic by domain name - NSGs cannot; Azure Firewall application rules can.

Restricted Content Discovery vs Restricted Access Control

3.1.1

Should overshared content stop appearing in Copilot and search, or should people lose access to it?

- *"stop it appearing in Copilot without disrupting the team"* → **RCD**
- *"only the legal group may open the site"* → **RAC**

Trap. Choosing RCD when the requirement is that unauthorised users must not be able to open the files.

On-behalf-of agent vs autonomous agent

3.1.4 3.1.6

Whose token does the agent use - a signed-in user's, or its own?

- *"assistant that acts for the signed-in user"* → **On-behalf-of - governed by user policies**
- *"nightly agent with no user present"* → **Autonomous - agent identity policies**

Trap. Assuming your All users MFA policy covers agents - it does not include agent identities or agents' user accounts.

AI gateway vs Foundry guardrails vs Defender for AI Services

3.1.7 3.1.8 3.1.9 3.1.10

Is the requirement about AI traffic, AI content, or detecting attacks?

- *"one app must not exhaust the token quota"* → **AI gateway (llm-token-limit)**
- *"scan what a tool returns before the agent uses it"* → **Foundry guardrail on tool response**
- *"SOC must be alerted to jailbreak attempts"* → **Defender for AI Services**

Trap. Expecting Defender for AI Services to block a prompt - it alerts. Blocking is guardrails, the gateway, or Defender real-time protection for agents (preview).

Web Application Firewall vs API Management

3.3.8 3.3.9

Is the requirement to block malicious requests, or to control which callers may use an API and how much?

- *"block SQL injection and XSS"* → **WAF managed rules (Prevention mode)**
- *"callers must present a valid Entra token, each limited independently"* → **API Management (validate-jwt, rate limits)**

Trap. Using a WAF to enforce per-consumer quotas or token validation - that is API Management.

Azure Bastion vs just-in-time VM access

3.2.2 3.2.3

Is the requirement to remove the public path to the VM, or to keep management ports closed until needed?

- *"RDP without a public IP, record sessions"* → **Azure Bastion (Premium for recording)**
- *"open port 3389 for one hour from one IP on request"* → **Just-in-time VM access**

Trap. Picking Bastion for "ports open only when needed", or JIT for "no public IP".

Agentless scanning vs the Defender for Endpoint agent

3.2.6 3.2.7 4.1.5

Do you need findings without installing anything, or real-time detection and response on the machine?

- *"vulnerability findings without installing anything"* → **Agentless scanning**
- *"detect and respond to attacker behaviour on the server"* → **Defender for Endpoint (EDR)**

Trap. Treating agentless scanning as a replacement for EDR.

Posture management vs workload protection

4.1.1 4.1.3

Is the requirement about how exposed things are, or about attacks happening now?

- *"prioritise findings, attack path, internet-exposed VM with a critical CVE"* → **Defender CSPM**
- *"alert on suspicious access to a storage account / SQL injection attempt"* → **Workload protection plan**

Trap. Expecting Defender CSPM to raise an alert for malware on a storage account - that is Defender for Storage.

Security Copilot roles vs underlying service roles

4.3.2 4.3.3

Does this role let someone use Security Copilot, or see the data Copilot reasons over?

- *"analyst can query Purview but not Sentinel through Copilot"* → **Missing Sentinel service role**
- *"restrict who can open Security Copilot"* → **Copilot contributor assignment**

Trap. Restricting Copilot contributor and believing that limits data exposure - data access was always the service roles.

Sentinel analytics tier vs data lake tier

4.2.7 4.2.9

Will this data drive detections and hunting, or is it kept for history and compliance?

- *"must be usable by analytics rules"* → **Analytics tier**
- *"keep seven years for compliance at low cost"* → **Data lake tier (total retention)**

Trap. Moving a table that feeds analytics rules to the data lake - the rules stop working.

Sentinel automation rule vs playbook

4.2.8

Is the requirement to route and manage incidents, or to take action in other systems?

- *"automatically assign and tag new incidents"* → **Automation rule**
- *"create a ServiceNow ticket / disable the user in Entra"* → **Playbook (run by an automation rule)**

Trap. Granting Playbook Operator to someone who must build playbooks - building needs Logic Apps permissions.

Windows Security Events via AMA vs Windows Forwarded Events

4.2.6

Should each server send its own Security log, or should endpoints forward to a collector?

- *"collect only these event IDs from each server"* → **Windows Security Events via AMA with custom XPath**
- *"endpoints must not connect to Azure directly"* → **Windows Forwarded Events via a collector**

Trap. Forwarding events with WEF and assuming the built-in SecurityEvent rules now cover them.

How to read a scenario

1. **Find the verb.** *Prevent, block, must not* wants a preventive control. *Detect, alert, notify* wants Defender or Sentinel. *Prove, report* wants compliance or audit.
2. **Find the subject.** A person, a workload, an agent, a network path or the data? That names the layer.
3. **Find the constraint that kills options.** *Without a credential. No public IP. No team can override. Without disrupting users. Without installing anything.*
4. **Find the scope.** *Every subscription, including future ones* means policy at a management group. *One secret only* means the narrowest role at the narrowest scope.
5. **Strike the answers that solve a different layer,** then the ones that detect when the question says prevent.

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

Which control?

The phrases that decide a question, and the answer they point to. Cover the right-hand side and test yourself.

SC-500 Academy posters
Back: scenario words and what they point to
Checked against Microsoft Learn on 20 October 2026

Domain 1 Identity, access, governance

"the same identity must survive a VM rebuild"	1.1.6
→ **User-assigned managed identity**	
"no credential in code or configuration, runs on Azure"	1.1.6
→ **Managed identity**	
"runs in GitHub Actions, no secret allowed"	1.1.4
→ **Workload identity federation: app registration or user-assigned MI**	
"three policies apply; one of them blocks"	1.1.2
→ **Blocked. Block beats every grant**	
"passkey or certificate; SMS must not count"	1.1.3
→ **Authentication strength, not plain MFA**	
"delegated vs application permission"	1.1.5
→ **Delegated = the user's reach. Application = tenant-wide, admin consent**	
"nobody holds the role until they need it; approval; four hours"	1.1.1
→ **PIM eligible assignment + role settings**	
"Contributor must not grant themselves secret access"	1.2.3
→ **Key Vault Azure RBAC permission model**	
"read one specific secret and nothing else"	1.2.3
→ **Key Vault Secrets User on that secret**	
"keys protected by HSMs; nobody may permanently delete"	1.2.2
→ **Premium SKU + purge protection**	
"app uses the URI with no version; old value restorable"	1.2.5
→ **New version, then disable the old one**	
"plaintext secrets on VM disks, AWS too, nothing installed"	1.2.6
→ **Agentless secret scanning (Defender CSPM or Servers Plan 2)**	
"no deployment failed, compliance still 40%"	1.3.1
→ **Deny only stops new requests: Modify or DeployIfNotExists + remediation**	
"ReadOnly lock broke an app that only reads blobs"	1.3.4
→ **Listing keys is a POST; ReadOnly blocks it**	
"which PCI DSS controls are we failing?"	1.3.2
→ **Regulatory compliance, after adding the standard**	
"stays visible, reason recorded, ends on its own"	1.3.3
→ **Exemption with an expiry date**	
"Owner at the management group, Reader at the subscription"	1.3.5
→ **Still Owner: assignments add up**	
"Resource Guard owned by the same administrator"	1.3.8
→ **Multi-user authorization stops mistakes, not a rogue admin**	
"must never be created, whatever tool deploys it"	1.3.9
→ **Azure Policy with Deny**	

Domain 2 Storage, databases, networking

"a SAS issued with no stored access policy must stop working"	2.1.4
→ **Rotate the key that signed it**	
"Shared Key disabled: what still works?"	2.1.1
→ **Entra ID and user delegation SAS**	
"attributable to a named user, never more than they have"	2.1.4
→ **User delegation SAS**	
"subnet allowed by the firewall, still 403"	2.1.2
→ **Network rules never grant; it needs a role or key**	
"monthly malware scan cap reached"	2.1.3
→ **Scanning stops for the month; uploads continue**	
"signed in with the SQL admin password, no MFA"	2.2.1
→ **Microsoft Entra-only authentication**	
"protected because Dynamic Data Masking is on"	2.2.1
→ **Not a boundary: WHERE clauses still reveal values**	
"auditing on at server and database level"	2.2.2
→ **Every event recorded twice**	
"SQL Server on a VM and Cosmos DB"	2.2.3
→ **One Defender for Databases plan; keep both types selected**	
"no application team can override it"	2.3.2
→ **Virtual Network Manager security admin rule (Deny)**	
"configuration saved, but has no effect"	2.3.2
→ **It was never deployed to the region**	
"NIC NSG denies at 150, subnet NSG allows"	2.3.1
→ **Blocked: inbound must pass both**	
"point-to-site users need Conditional Access"	2.3.4
→ **OpenVPN with Microsoft Entra ID authentication**	
"inspect spoke-to-spoke; internet leaves via on-premises"	2.3.3
→ **Private routing policy + 0.0.0.0/0 prefix, no internet policy**	
"legacy app, MFA and device compliance, no VPN"	2.3.5
→ **Entra Private Access app as an enterprise application**	
"a colleague at home still reaches the account"	2.3.6
→ **Disable public network access**	
"nslookup on-premises returns a public IP"	2.3.6
→ **Hybrid DNS for the private zone**	
"partner tenant, overlapping addresses, approve each connection"	2.3.7
→ **Private Link service**	
"broad network rule let HTTPS to any site through"	2.3.8
→ **Network rules run before application rules**	
"traffic is not reaching the firewall"	2.3.9
→ **Network Watcher next hop**	

Domain 3 Security for AI

"hide it from Copilot without disrupting the team"	3.1.1
→ **Restricted Content Discovery**	
"unauthorised users must lose access entirely"	3.1.1
→ **Restricted Access Control**	
"Microsoft 365 E5 and no Copilot licences"	3.1.1
→ **Data access governance activity reports only**	
"user can open the file; Copilot will not summarise it"	3.1.2
→ **Label grants VIEW but not EXTRACT**	
"protection works in one environment, not the new one"	3.1.3
→ **Threat detection is set up per environment**	
"autonomous agent; the All users policy never applies"	3.1.4
→ **Target agent identities in Conditional Access**	
"agent built by someone who has left; nobody accountable"	3.1.6
→ **Access package with expiry + sponsor lifecycle**	
"tenant-wide inventory of agents, and block some"	3.1.11
→ **Microsoft 365 admin center agent management**	
"one app's loop starves every other consumer"	3.1.7
→ **llm-token-limit keyed per subscription**	
"over-limit calls refused before the model"	3.1.7
→ **estimate-prompt-tokens="true" on llm-token-limit**	
"the agent has its own guardrail"	3.1.9
→ **It replaces the model's guardrail entirely**	
"show what the prompt said in the alert"	3.1.8
→ **Suspicious prompt evidence on the AI plan**	
"Defender CSPM on, Defender for AI Services off"	3.1.10
→ **AI posture and discovery, no runtime alerts**	

Domain 3 Servers, containers, apps

"server-side encryption is on; still flagged"	3.2.1
→ **Encryption at host: temp disks and caches**	
"every administrative session must be recorded"	3.2.2
→ **Azure Bastion Premium**	
"admins can still RDP straight from home"	3.2.2
→ **Remove public IPs and open ports**	
"Servers Plan 2 on, FIM reports nothing"	3.2.6
→ **File integrity monitoring must be turned on**	
"Azure VM, OS configuration audit"	3.2.9
→ **Machine Configuration extension + system-assigned identity**	
"on-premises server, same Policy and RBAC"	3.2.4
→ **Azure Arc**	
"a process that was not in the image"	3.3.1
→ **Binary drift detection**	
"ex-employee still reaches the cluster"	3.3.2
→ **Disable AKS local accounts**	
"whatever a developer submits, never privileged"	3.3.2
→ **Azure Policy for AKS, Deny at admission**	
"registry admin password in the pipeline"	3.3.3
→ **Disable the ACR admin account; use an identity**	
"key in a partner's integration URL"	3.3.5
→ **Function key: bearer secret, no identity**	
"workflow callback URL circulated"	3.3.6
→ **The URL holds a SAS: it is the credential**	
"the deployment console is still reachable"	3.3.7
→ **SCM site has its own access rules**	
"attack logged, app still exploited"	3.3.8
→ **WAF is in Detection mode**	
"gateway policies must be real, not advisory"	3.3.9
→ **Backend accepts only API Management**	

Domain 4 Posture and monitoring

"attack path analysis shows nothing"	4.1.1
→ **Plan enabled without Owner: agentless scanning never started**	
"secure score 82%, yet an obvious attack path"	4.1.1
→ **Scores grade findings; attack paths chain them**	
"only Defender for Servers Plan 1; add PCI DSS"	4.1.2
→ **Needs another plan to unlock standards**	
"subscriptions created next year"	4.1.3
→ **Policy at the management group**	
"AWS machines, Arc auto-provisioning declined"	4.1.4
→ **Agentless scanning still covers them; Arc unlocks the rest**	
"assets nobody remembers owning"	4.1.6
→ **Defender EASM**	
"analyst cannot close an incident"	4.2.2
→ **Microsoft Sentinel Responder**	
"40 solutions installed, nothing detects"	4.2.3
→ **Templates are not active rules**	
"duplicate incidents for Defender alerts"	4.2.4
→ **Turn off Microsoft incident creation rules**	
"firewall appliance logs"	4.2.5
→ **CEF via a Linux forwarder with AMA**	
"only these event IDs, nothing else"	4.2.6
→ **Custom XPath in the data collection rule**	
"forwarded events, SecurityEvent query is empty"	4.2.6
→ **They land in WindowsEvent**	
"no connector, keep 12 months, small subset detects"	4.2.7
→ **Custom table via Logs Ingestion API, split tiers**	
"playbook never runs, no error"	4.2.8
→ **Sentinel needs Automation Contributor on its resource group**	
"data from 14 months ago"	4.2.9
→ **Search job or KQL job on the data lake**	
"which emails did the attacker open?"	4.2.10
→ **MailItemsAccessed, Audit (Standard)**	
"what did they search for in the mailbox?"	4.2.10
→ **SearchQueryInitiated, Audit (Premium)**	
"Global Administrator cannot provision capacity"	4.3.1
→ **Needs Azure Owner or Contributor too**	
"Copilot answers Purview questions, not Sentinel"	4.3.2
→ **The user's own service roles decide**	
"bill tripled, analyst usage unchanged"	4.3.4
→ **Scheduled agents consuming SCUs**	
"runs daily as my admin account"	4.3.4
→ **Give the agent its own agent identity**	

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

Who wins?

When several controls apply at once, these rules decide the outcome. Learn the order, and you can predict the result before you test it.

SC-500 Academy posters
Front: identity, governance and data
Checked against Microsoft Learn on 20 October 2026

Conditional Access: how policies combine

1.1.2 1.1.3

Sign-in first factor done → **Every policy in scope applies** no priority order →
Any policy blocks? block wins → **All grant controls met** from every policy →
Access + session controls

- **Exclusions beat inclusions.** A user excluded by a policy is never in its scope, even if a group includes them.
- **Report-only** policies are evaluated and logged, never enforced.
- **Authentication strength** names the acceptable methods; plain "require MFA" accepts any second factor.
- Conditional Access only sees Microsoft Entra sign-ins. SQL logins, storage keys and SAS tokens never reach it.
- **Agents:** one acting on behalf of a user is evaluated as that user. One using its own agent identity or agent user account needs policies that target it: *All users* does not include agent user accounts.
- Proof: sign-in logs, *Conditional Access* tab - every policy that evaluated and its result.

PIM: eligible is not active

1.1.1

Eligible assignment grants nothing yet → **Activate** MFA, justification, approval →
Active for a set time → **Expires on its own**

- Activation rules (maximum duration, MFA, justification, approval) are **role settings**: every eligible user of that role gets them.
- Separate settings for Microsoft Entra roles, Azure resource roles and PIM for Groups.
- PIM limits *how long* privilege exists, not what the role can do while active.

App permissions and consent

1.1.4 1.1.5 1.1.6

Permission type	Acts as	Reach	Who can consent
Delegated	The signed-in user	Only what that user can reach	Users, if consent settings allow, for low-risk permissions
Application	The app itself, no user	Tenant-wide	An administrator only

- The **application object** lives in the home tenant; every tenant that consents gets its own **service principal**. Deleting the app registration deletes its home-tenant service principal; service principals in other tenants stay.
- Restricting user consent does not remove grants already given; review and remove them.
- A **managed identity** is a service principal whose credential Azure manages. System-assigned dies with its resource; user-assigned survives and can be shared.

Azure RBAC: permissions add up

1.3.5 1.3.6 1.3.7

Management group → **Subscription** → **Resource group** → **Resource** → **Effective = union of all**

- Assignments are **inherited downward and additive**. A narrower Reader removes nothing from a broader Owner.
- **NotActions and NotDataActions subtract only inside their own role.** Another role can still grant the action. They are not a deny.
- **Deny assignments** win over role assignments, but you cannot create them directly; Azure creates them (for example managed applications, deployment stacks). Customer-managed deny assignments are in private preview.
- **Actions** are the control plane, **DataActions** the data plane: Owner has no DataActions, so it reads no blobs or secrets directly, **but it can list storage account keys**.
- Azure roles and Microsoft Entra roles are separate systems.

Entra roles and Azure roles: two systems

1.3.5 1.3.6

	Microsoft Entra roles	Azure roles (RBAC)
Control	The directory: users, apps, policies	Azure resources: subscriptions down to a resource
Example	Global Administrator, Security Administrator	Owner, Contributor, Key Vault Secrets User
Scope	Tenant, administrative unit, or a single app	Management group, subscription, group, resource
Custom roles	Entra custom roles (P1 or P2)	Azure custom roles, with assignable scopes

- Holding Global Administrator does not grant Azure access. A Global Administrator can **elevate** to User Access Administrator at root scope, and every use should be temporary and audited.
- Least privilege on both: the smallest role at the narrowest scope, made eligible through PIM.

Resource locks

1.3.4

- Locks apply to **Azure Resource Manager (control-plane) operations only**, and are inherited by everything below the scope.
- The **most restrictive** lock in the chain wins.
- **CanNotDelete**: read and modify, no delete. **ReadOnly**: read only, including blocking POST operations such as listing storage account keys, which can break apps that "only read".
- Removing a lock needs `Microsoft.Authorization/locks/*`: Owner, User Access Administrator, and a few specialised built-in roles.

Azure Policy: what Deny does and does not touch

1.3.1 1.3.3

Create or update request → **Disabled** skipped → **Append / Modify** →
Deny → **Audit, Manual, AuditIfNotExists** → **DenyAction** →
Resource provider → **AuditIfNotExists / DeployIfNotExists** after success

- **Deny stops new create and update requests.** Resources that already exist are only reported non-compliant.
- Fix existing resources with **Modify or DeployIfNotExists plus a remediation task**; both need the assignment's managed identity.
- An assignment at a management group reaches every subscription below it, including future ones.
- **Exemption** (Waiver or Mitigated, optional expiry): stays in compliance results as Exempted. **Exclusion**: drops out of evaluation entirely.
- Owner plus a Deny policy still cannot create the forbidden resource. RBAC asks who; Policy asks what.

Backup protection: three layers

1.3.8

Soft delete deleted backups kept 14 days or more → **Immutable vault** no early deletion →
Multi-user authorization a Resource Guard approves risky changes

- Multi-user authorization only helps when **someone else controls the Resource Guard**, ideally in another subscription or tenant. Same owner: it stops mistakes, not a rogue administrator.
- Locking immutability and **always-on** soft delete are **irreversible**.

Key Vault: two gates and a safety net

1.2.2 1.2.3 1.2.4

Network vault firewall, private endpoint → **Authorization** Azure RBAC or access policies →
Data plane

- **The vault firewall guards the data plane only.** Management operations (tags, SKU, access policies) still go through Azure Resource Manager.
- **One permission model per vault.** Under access policies, anyone who can write the vault can grant themselves secret access; under Azure RBAC that needs role-assignment rights.
- **Soft delete** keeps deleted vaults and objects for 7 to 90 days. **Purge protection** blocks purging until retention ends and **cannot be turned off**.

Storage: both gates must pass

2.1.1 2.1.2 2.1.4

Network firewall, private endpoint → **Authorization** Entra ID, Shared Key, SAS → **Data**

- **Network rules subtract; they never grant.** An allowed subnet still needs a role, a key or a SAS.
- Disabling **Shared Key** stops account keys, account SAS and service SAS. Entra ID and **user delegation SAS** keep working.

To revoke	Do this
Service SAS bound to a stored access policy	Delete or change the policy
Any SAS signed with an account key	Rotate that key
User delegation SAS	Revoke user delegation keys

Three kinds of SAS

2.1.4

SAS	Signed with	Revoke by
Account SAS	Account key	Rotating that key
Service SAS	Account key	Deleting its stored access policy, or rotating the key
User delegation SAS	An Entra-issued user delegation key	Revoking user delegation keys

- Only a user delegation SAS can be traced to a person and is limited to that person's own permissions.
- A SAS expiration policy sets a maximum lifetime; violations are logged (default) or blocked.

Azure SQL

2.2.1 2.2.2

- **Firewall:** database-level IP rules are checked first, then server-level rules.
- **Microsoft Entra-only authentication** rejects SQL logins - the only way Conditional Access and MFA see every connection. Set the Entra admin first.
- **Auditing** at server and database level both run: each event is recorded twice.
- Dynamic Data Masking changes what a query returns, not what can be queried.

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

Who wins?

The order a packet, a request or an alert is checked in decides what happens to it. Each chain reads left to right.

SC-500 Academy posters
Back: networks, applications, AI and monitoring
Checked against Microsoft Learn on 20 October 2026

NSGs: the path a packet walks

2.3.1 2.3.9

Inbound

Subnet NSG → Network interface NSG → **VM**

Outbound

VM → Network interface NSG → **Subnet NSG**

- Inside an NSG, rules run from the **lowest priority number** (100 to 4096); the first match ends evaluation.
- Default rules (65000 and up) allow traffic within the virtual network and deny inbound from the internet.
- NSGs are **stateful**: return traffic is allowed automatically.
- Proof: *Effective security rules* on the network interface, and IP flow verify.

Virtual Network Manager: admin rules first

2.3.2

Security admin rule → NSG rules → **Traffic**

Admin rule action	Result
Deny	Dropped. No NSG can allow it.
Always allow	Allowed. NSGs are not evaluated.
Allow	Passed on: NSGs still decide.

- A configuration does nothing until it is **deployed** to each target region.

Network Watcher: which tool answers what

2.3.9

Question	Tool
Is this flow allowed, and by which rule?	**IP flow verify**
Where does this packet go next?	**Next hop**
Which rules apply to this network interface, merged?	**Effective security rules**
Can A reach B end to end, and where does it fail?	**Connection troubleshoot**
What actually flowed?	**Virtual network flow logs** (NSG flow logs can no longer be created)

Azure Firewall: rule types beat priorities

2.3.8

Threat intel if on → **DNAT rules** → **Network rules** →
Application rules HTTP, HTTPS, MSSQL → **Infrastructure rules** → **Deny**

- **Network rules always run before application rules,** whatever the rule collection group priority. A network rule match ends processing.
- Within each rule type: rule collection groups by priority, then rule collections by priority. Parent policy groups come before child policy groups.
- Threat intelligence, when on, is processed **before every rule**: **Alert and deny** blocks known-malicious traffic; **Alert only** just logs it.

Routing and private endpoints

2.3.6 2.3.9

- Azure picks the route with the **longest matching prefix**. For the same prefix: user-defined route, then BGP, then system route.
- **Exception:** system routes for the virtual network, peerings and service endpoints win even over more specific BGP routes, and no route table overrides a service endpoint route.
- Traffic only reaches a firewall that a route sends it to. Proof: *Next hop* in Network Watcher.
- A private endpoint adds a private path; the **public endpoint stays open** until public network access is disabled.
- Clients must resolve the name to the private IP: the private DNS zone has to be linked or forwarded from every network that uses it.

Remote access paths

2.3.3 2.3.4 2.3.5 2.3.7

- **Point-to-site with Microsoft Entra ID** needs the **OpenVPN** tunnel type; only then do Conditional Access and MFA apply.
- **Virtual WAN routing intent**: a **private** routing policy sends branch and spoke traffic through the hub firewall; an **internet** routing policy sends internet traffic through it and straight out. **Forced tunnel** to on-premises is a private policy with 0.0.0.0/0 added as a prefix, and **no** internet policy.
- **Entra Private Access**: the Global Secure Access client sends traffic for published apps through Microsoft's edge to a private network connector. Conditional Access attaches to the app as an **enterprise application**.
- A **Private Link service** lets another tenant reach your load-balanced service through their own private endpoint, which you approve. Overlapping address spaces are fine.

Security Copilot: whose permissions?

4.3.2 4.3.3

Copilot role owner or contributor → **Plugin** enabled for the workspace →
User's own service roles → **Answer**

- Copilot roles open the door; **service roles decide what is in the room**. A contributor with no Sentinel role gets no Sentinel answers.

Web Application Firewall

3.3.8

Custom rules by priority → **Managed rules** anomaly score → **Mode**

- Each matched managed rule adds to an **anomaly score**; a score of **5 or more** (one critical match) blocks.
- **Detection mode logs and blocks nothing.** Only Prevention mode blocks.
- Changing the rule set version resets overrides and exclusions (Front Door; Application Gateway when done in the portal): **reapply them**.

API Management policies

3.3.9

Inbound → **Backend** → **Outbound**

- **on-error** runs instead when a step fails.
- Scopes nest: global, workspace, product, API, operation. Where <base /> sits decides whether the outer scope runs before or after.
- **The gateway only protects a backend that cannot be reached any other way.**

App Service and AKS

3.3.2 3.3.7

- **Access restrictions** run by priority; once any rule exists, unmatched traffic is denied by default (configurable).
- The **SCM (Kudu) site** has its own rule set unless it is set to use the main site's rules.
- With **Require authentication** set, App Service authentication turns away unauthenticated requests before the app's code runs. It proves who the caller is; what they may do is still the app's decision.
- **AKS:** with local accounts disabled, every user goes through Microsoft Entra ID. Azure Policy for AKS evaluates every request at admission; *audit* reports, *deny* rejects.

Defender for Cloud: where a plan is set

4.1.3

Management group policy DeployIfNotExists → **Subscription** plan on or off →
Resource override where supported

- Plans are switched on **per subscription** and stay on after the resources are deleted.
- Some plans can also be set per resource, overriding the subscription: **Defender for Servers Plan 1**, **Storage**, **App Service**, **AI services**.
- A policy at the management group turns plans on for subscriptions that do not exist yet.

AI: which control acts first

3.1.3 3.1.9

User input → **Tool call** agents → **Tool response** agents → **Output**

- **Foundry guardrails** act at these intervention points (agent guardrails and tool points: preview). An agent with its own guardrail **ignores the model's guardrail entirely**; with none, it inherits the model's.
- **Copilot Studio real-time protection** (preview) checks each planned tool call. If no decision returns in about one second, the default is to **allow**.
- **Defender for AI Services**, the Defender for Cloud plan, **alerts; it does not block.** Blocking is guardrails, the AI gateway, or Defender real-time protection rules for Foundry agents (preview).

Sentinel automation and retention

4.2.8 4.2.9

Incident or alert → **Automation rules** in order → **Playbook** Logic App

- Automation rules run in their **order number**; a rule can change the incident, suppress it until an expiry date, or run a playbook.
- Two permissions: Sentinel needs **Microsoft Sentinel Automation Contributor** on the playbook's resource group; the playbook needs its own identity's permissions.

Analytics tier rules and hunting → **Data lake** until total retention → **Deleted**

- Data past analytics retention is invisible to analytics rules. Reach it with a KQL job or a search job; restore does not work on data lake tier data.

Does it block, or only tell you?

1.3.1 4.1.1

Control	Blocks	Records or alerts
Conditional Access	Block grant	Report-only mode
Azure Policy	Deny; DenyAction (deletes)	Audit, AuditIfNotExists
SAS expiration policy	Block	Log (default)
WAF	Prevention mode	Detection mode
Foundry guardrail	Annotate and block	Annotate
Defender real-time protection for agents	Custom rule	Default rule (audit)
Defender for Cloud plans, including AI Services		Alerts
Sentinel analytics rules		Alerts and incidents
Sentinel automation, playbooks	Act after detection	

Read the verb in the question: *prevent* needs the left column, *detect* the right.

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

The AI security stack

An AI system asks, decides, acts and reads data. Each SC-500 control sits on one of those steps. Know the layer and you know the answer.

SC-500 Academy posters
Front: where each control acts
Checked against Microsoft Learn on 20 October 2026

Where each control acts

Read top to bottom: a request starts with someone asking and ends at the data. Every SC-500 security-for-AI bullet sits on one layer.

Who asks
people and agents

A person in Microsoft 365 Copilot
Copilot answers with the signed-in user's own permissions, through Microsoft Graph. No privileged index.

Copilot Studio agent
Built by any licensed maker. Generative orchestration plans which tool to call next.

Foundry agent or app
Calls a model deployment, and for agents, tools such as search, functions and APIs.

Inventory
what agents exist

Agent management in the Microsoft 365 admin center 3.1.11
Agents, All agents: the tenant registry. Block, delete (30-day restore), assign a new owner, approve store submissions.

Data and AI security dashboard 3.1.10
Defender for Cloud: AI resources found, prompts scanned, alerts, internet-exposed grounding sources. Full view needs Defender CSPM plus the protection plans.

Identity
who the agent is

Conditional Access for Agent ID 3.1.4
Target the token subject: the user for on-behalf-of agents, agent identities or blueprints for autonomous ones, the agent user (preview) for agents with accounts. All users skips agent users.

Agent ID access 3.1.6
Owners and sponsors, access packages that expire, sponsorship lifecycle workflows. Access decays unless someone renews it.

Blast radius in Defender XDR 3.1.5
If the agent were subverted, what could it reach? Its permissions, tools, grounding sources, and for on-behalf-of agents, the user's.

Runtime
what it is allowed to do now

Copilot Studio real-time protection (preview) 3.1.3
Defender checks each tool call before it runs. In the new rules experience the Default rule only audits; a custom rule blocks. Generative orchestration only.

AI gateway in API Management 3.1.7
One chokepoint in front of models: token limits per consumer, content safety, the model key kept off the apps.

Foundry guardrails 3.1.9
Controls on user input, output, and for agents (preview) tool calls and tool responses. Annotate, or annotate and block.

Data
what it can read

SharePoint oversharing 3.1.1
Data access governance reports find it. Restricted Content Discovery hides a site from Copilot; Restricted Access Control removes access.

Purview DSPM (was DSPM for AI) 3.1.2
Who used which AI app with what data. Labels with encryption: Copilot needs VIEW and EXTRACT to summarise.

Detection
who notices

Defender for AI Services 3.1.8
Runtime threat detection on prompts and responses: jailbreaks, data leakage, credential theft. Alerts; never blocks.

Defender CSPM 3.1.10
Discovers AI resources, builds the AI bill of materials, finds AI attack paths. Posture, not runtime alerts.

One indirect prompt injection, five places to stop it

An attacker never touches the agent. They plant instructions in content it will read, and let its own access do the rest.

Instructions planted in a document 3.1.1 3.1.2
A file the agent grounds on contains hidden instructions, often in a site shared far too widely.
Stop it: Fix the oversharing; RCD or RAC while you review; labels without EXTRACT.

The agent reads it 3.1.9
Grounding or a tool returns the poisoned text into the agent's context.
Stop it: A guardrail with indirect attack detection on the tool response.

The agent plans an action 3.1.3 3.1.9
It decides to send an email or call an API with data it holds.
Stop it: A real-time protection custom rule blocks the tool call; a tool call control in Foundry.

The action runs with the agent's access 3.1.4 3.1.6
Whatever the agent identity, or the delegated user, can reach is in play.
Stop it: Least privilege, expiring access, Conditional Access for unapproved agents.

Someone notices 3.1.5 3.1.8
The SOC needs the alert, the prompt and the reach.
Stop it: Defender alerts with prompt evidence; blast radius; DSPM activity.

Licence gates

3.1.1 3.1.4 3.1.8

Capability	Needs
Snapshot DAG reports, RCD, RAC	SharePoint Advanced Management. Unlocked automatically if anyone in the tenant has a Microsoft 365 Copilot licence
DAG activity reports	Microsoft 365 E5, up to 10,000 sites, after enabling data collection
Conditional Access for agents	Microsoft 365 E7, or Agent 365 with at least Entra ID P1 or Microsoft 365 E3
Generative Copilot Studio agents	Microsoft 365 Copilot, a Copilot Studio licence or pay-as-you-go. E5 alone has only the Teams plan
Agent inventory and basic actions	Microsoft 365 plans. Policy templates and tool control need E7 or Agent 365
Defender for AI Services	The plan, per subscription. 30-day trial capped by tokens scanned
Data security for AI interactions	Purview pay-as-you-go meters or Agent 365; enable it in Foundry
llm-token-limit	Any API Management tier except Consumption

Dates that changed the answers

3.1.3 3.1.8

When	What changed
1 July 2026	Foundry agent threat protection, discovery and posture move to Microsoft Agent 365, and Foundry agent data leaves the Data and AI security dashboard. Defender for AI Services keeps protecting Foundry Models.
1 July 2026	Copilot Studio threat detection alerts move to Agent 365 observability. Microsoft's pages disagree on whether real-time protection continues without an Agent 365 licence: **needs verification**.
31 July 2026	New enablement of Restricted SharePoint Search blocked. Plan around Restricted Content Discovery.

Check Microsoft Learn before answering any question that depends on these.

Words you must not mix up

Term	Means
Agent identity blueprint	The template agent identities are created from. Cannot act on resources
Agent identity	The principal that does the work
Agent user	A user-shaped account linked to one agent identity
Sponsor	The accountable human for an agent
Prompt Shields	Attack detection: jailbreaks (user prompt attacks) and indirect attacks
Harm categories	Content rules: hate, sexual, violence, self-harm
Generative orchestration	The agent plans its own tool calls. The only Copilot Studio kind real-time protection checks

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

The AI security stack

The details SC-500 questions turn on: what each control checks, where it is switched on, and what it leaves alone.

SC-500 Academy posters
Back: how each control behaves
Checked against Microsoft Learn on 20 October 2026

AI gateway policies 3.1.7

Policy	Does	Returns
`llm-token-limit`	Tokens per minute and quotas, per counter key (subscription, IP or expression)	429 rate, 403 quota
`estimate-prompt-tokens`, an attribute of llm-token-limit	Estimates prompt tokens before forwarding, which can reduce over-limit calls reaching the model	
`llm-content-safety`	Sends prompts or completions to Azure AI Content Safety. `shield-prompt` is off by default	403 when blocked
`llm-semantic-cache-*`	Returns cached completions for similar prompts. Partition with `vary-by` or callers see each other's answers	
`authentication-managed-identity`	The gateway calls the model as itself; apps never hold the key	

- In Foundry: **Manage, AI Gateway**, at Foundry resource level. New projects join automatically; existing projects must be added.
- **The counter key decides fairness.** A constant key makes every consumer share one bucket.

Copilot Studio real-time protection (preview) 3.1.3

Agent plans a tool call → **Defender evaluates** within about 1 s → **Audit or block** the rule decides

- **Two sides, both required.** Defender portal: Settings, Security for AI, Get started, Copilot Studio step, real-time protection on. Power Platform admin center: Security, Threat detection, per environment.
- **New rules experience (Agent 365):** the built-in Default rule audits every agent; to block, create a custom rule under Settings, Security for AI, Policies & rules, Real-time protection. The legacy Defender for Cloud Apps path stays unchanged for tenants that keep it.
- Only **generative orchestration** agents. Classic agents are skipped.
- No answer in time: the default is **allow**; you can change it to block.
- Blocks are recorded as behaviours. When a blocking rule covers an agent, near-real-time alerts are not generated.
- Evidence it works: the Copilot Studio step shows **Connected**.

Foundry guardrails 3.1.9

Intervention point	Models	Agents (preview)
User input	**Yes**	**Yes**
Tool call	No	**Yes**, tools that support it
Tool response	No	**Yes**, tools that support it
Output	**Yes**	**Yes**

- A guardrail is a set of controls: **risk** + **intervention point** + **action** (annotate, or annotate and block; agents only annotate and block).
- **An agent's own guardrail replaces the model's entirely.** No agent guardrail: it inherits the model deployment's.
- Default `Microsoft.DefaultV2` cannot be edited. Azure OpenAI default: harm categories at Medium, jailbreak on prompts, protected material on completions. **No indirect attack detection by default.**
- Groundedness and Spotlighting apply to models only. Blocklists: up to 10,000 terms, Azure OpenAI only.

Conditional Access for agents 3.1.4

Agent pattern	Token subject	Target
On-behalf-of	The signed-in user	Users and groups
Autonomous	The agent identity	Agent identities or blueprints
Agent user	The agent's user account	That user account (preview)

- A policy on one subject does not cover the others.
- Agents cannot answer MFA. For agent identities the grant control is **Block**, with conditions such as **agent risk** (preview).
- Agent users on an Intune-managed Windows 365 Cloud PC for Agents can also be held to a **compliant device** or **compliant network** (preview).
- Licence: Microsoft 365 E7, or Agent 365 with Entra ID P1 or Microsoft 365 E3. Agent risk conditions also need ID Protection: Entra ID P2 or E5.
- Not evaluated for blueprint token requests that create agents, with security defaults, or when an API key is used instead of an Entra token.

Agent ID access and the agent registry 3.1.5 3.1.6 3.1.11

- **owner**: blueprint and agent identity. **sponsor**: blueprint, agent identity, agent user. **manager**: agent user.
- Access packages give agents access that **expires** unless the sponsor asks to extend it.
- Sponsorship lifecycle workflows move sponsorship when a sponsor leaves.
- Microsoft 365 admin center, Agents, All agents: install, block, delete and restore (30 days), assign a new owner, start or stop a Foundry agent.
- Blast radius: Defender incident graph, **View blast radius**. Needs Exposure Management read and Sentinel data lake onboarding before 23 September 2026 (legacy incident experience); it only reaches assets classified as critical.

Oversharing and DSPM for AI 3.1.1 3.1.2

Control	Changes access?
Restricted Content Discovery	No. Hides the site from Copilot and org-wide search
Restricted Access Control	Yes. Only the named groups can open the site
Label with encryption, no EXTRACT	No. The user opens it; Copilot cannot summarise it
DLP for Microsoft 365 Copilot	Stops Copilot processing labelled content

- Microsoft 365 Copilot prompts and responses live in the user's mailbox: **eDiscovery** or the AI interaction event in activity explorer.
- Copilot in Fabric, Security Copilot and third-party apps need a **collection policy**, with content capture where needed.
- DSPM for AI is now **DSPM for AI (classic)**. The new **DSPM** (Purview portal, Solutions, DSPM) replaces it and adds AI observability for apps and agents.
- Reports need at least a day to fill. RCD can take more than a week on very large sites.

SharePoint controls that shrink what Copilot can find 3.1.1

- Default sharing links set to **Specific people**, not the whole organisation.
- Hide the **Everyone except external users** claim from the sharing picker.
- Restrict member sharing on sensitive sites, so owners handle access requests.
- **Site access reviews** from a data access governance report: the site owner decides what was oversharing.
- **Inactive site policies**: every abandoned site is more content Copilot reasons over.
- Hiding is not fixing: RCD buys time, permissions are the fix.

Defender for AI Services 3.1.8 3.1.10

Component	Adds	Status
Suspicious prompt evidence	Redacted prompt snippets in each alert	GA
Data security for AI interactions	Foundry app and agent interactions go to Purview	Now set in Foundry
AI model security	Scans models in Azure Machine Learning	Preview

- Enable per subscription: Environment settings, Defender plans, **AI services**. Owner or Contributor.
- Without prompt evidence, alerts still fire but **the prompt is masked**.
- Enforce everywhere with the built-in DeployIfNotExists policy *Enable threat protection for AI workloads*. *Configure Microsoft Defender threat protection for AI Services* keeps new plan capabilities switched on as they are added.

Pick the layer from the requirement

"nobody outside the team should find it through Copilot"	→ **Restricted Content Discovery**
"unauthorised users must lose access"	→ **Restricted Access Control**
"what did users type into AI apps"	→ **Purview DSPM, eDiscovery, collection policies**
"block the risky tool call before it runs"	→ **Real-time protection, custom blocking rule**
"no agent may sign in unless approved"	→ **Conditional Access for agent identities**
"access must expire if nobody renews it"	→ **Access package for the agent identity**
"one app must not use everyone's tokens"	→ **AI gateway token limit**
"scan what a tool returns"	→ **Agent guardrail, tool response control**
"tell the SOC about jailbreak attempts"	→ **Defender for AI Services**
"which AI resources do we even have"	→ **Defender CSPM, Data and AI security dashboard**
"find and block shadow agents"	→ **Microsoft 365 admin center agents**
"what could this agent reach if subverted"	→ **Blast radius in Defender XDR**

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

Posture and monitoring

Posture management tells you what is wrong. Workload protection tells you what is happening. Exposure management shows what an attacker sees.

SC-500 Academy posters
Front: Defender for Cloud
Checked against Microsoft Learn on 20 October 2026

Foundational CSPM or Defender CSPM? 4.1.1

Capability	Foundational (free)	Defender CSPM
Recommendations, secure score, inventory	**Yes**	**Yes**
Microsoft cloud security benchmark	**Yes**	**Yes**
Other regulatory standards	Needs a paid plan	**Yes**
Governance rules (owner, due date)	No	**Yes**
Cloud security explorer	No	**Yes**
Attack path analysis	No	**Yes**
Agentless scanning for machines	No	**Yes**
Risk prioritisation, AI security posture	No	**Yes**

- **Enable Defender CSPM as Subscription Owner.** Anyone else can switch it on, but agentless scanning isn't enabled, so attack paths and the explorer lack vulnerability data.
- Classic secure score (Azure portal) tracks benchmark controls; the Defender portal's Cloud Secure Score is risk-weighted. Neither is an attack path, which is a chain: exposure + vulnerability + identity + something valuable.

Regulatory compliance 4.1.2 1.3.2

Standard an Azure Policy initiative → **Controls** → **Recommendations** → **Your resources**

- The benchmark is assigned by default. Other standards need any paid plan **except Servers Plan 1 or APIs Plan 1**.
- Adding a standard: Microsoft's pages name different roles (Policy Contributor; Resource Policy Contributor plus Security Admin). Owner satisfies both.
- Accepted risk: a **waiver exemption** (expiry optional), not removing the resource from scope.
- The dashboard shows how your resources score against a framework. It is not an audit report.

DevOps security 1.3.9 4.1.1

- Connect **Azure DevOps, GitHub or GitLab** in Environment settings.
- Microsoft Security DevOps runs scanners, including infrastructure-as-code checks, in the pipeline.
- **Pull request annotations** and code-to-cloud mapping need Defender CSPM.
- DevOps recommendations do not affect the secure score.
- A Deny policy still stops a non-compliant template at deployment, whichever tool sends it.

Workload protection plans 4.1.3

Plan	What it adds	Watch for
Servers Plan 1	Defender for Endpoint (EDR), vulnerability assessment	Can be enabled per resource
Servers Plan 2	Plan 1 + premium vulnerability management, agentless scanning with malware scanning, file integrity monitoring, JIT, OS configuration assessment, free security-data ingestion	FIM is off until you turn it on
Containers	Posture, image vulnerabilities, runtime threats, admission control, binary drift	Absorbed Defender for Kubernetes and for Container Registries
Storage	Activity alerts, on-upload malware scanning, sensitive data threat detection	Malware scanning stops at the monthly cap
Databases	Four types: Azure SQL, SQL servers on machines, open-source relational, Cosmos DB	One switch turns on all four; deselect any you do not want
Key Vault, Resource Manager	Unusual access to vaults; suspicious control-plane operations	Legacy plans deprecated; fixed pricing model
App Service, APIs	Attacks on web apps; API inventory and threats	APIs Plan 1 does not unlock standards
AI services	Runtime alerts on prompts and responses	Discovery comes from Defender CSPM

- All are **off by default**, enabled per subscription (some per resource). Deleting a lab resource group leaves a subscription plan on.
- **Deploy them with Azure Policy at a management group** so new subscriptions inherit them.

Anatomy of an attack path 4.1.1

Internet exposure open port, public IP → **Vulnerable machine** critical CVE → **Its identity** managed identity → **Its permissions** role on a storage account → **Sensitive data**

- Each box alone is one recommendation among thousands. **The chain is one prioritised finding.**
- **Cloud security explorer** queries the same graph directly: "internet-facing VMs with a critical vulnerability and access to sensitive data" is one query.
- The graph is fed by agentless scanning, Defender Vulnerability Management, container image scanning, secret scanning and data classification. Missing inputs mean missing paths.

Which plan raises that alert? 4.1.1 4.1.3

"malware uploaded to a blob"	→ **Defender for Storage**
"SQL injection attempt on Azure SQL"	→ **Defender for Databases (Azure SQL)**
"unusual access to a key vault"	→ **Defender for Key Vault**
"suspicious ARM operations from a new location"	→ **Defender for Resource Manager**
"crypto-mining process on a VM"	→ **Defender for Servers (Defender for Endpoint)**
"a binary that was not in the container image"	→ **Defender for Containers**
"jailbreak attempt against an Azure OpenAI deployment"	→ **Defender for AI Services**
"internet-exposed VM with a critical CVE"	→ **No alert: a Defender CSPM attack path**

Multicloud, vulnerabilities and attack surface 4.1.4 4.1.5 4.1.6

- **AWS and GCP**: security connectors in Environment settings. Azure Arc auto-provisioning gives their machines the full Defender for Servers feature set; decline it and agentless scanning still covers them, but Arc-dependent features do not.
- **Defender Vulnerability Management** for Azure VMs: through the Defender for Endpoint extension (on by default with a Servers plan) or agentless disk scanning. CMK-encrypted disks need Key Vault permissions first.
- **Defender EASM** looks from the outside, from seeds: domains, IP blocks, ASNs. Its own Azure resource and bill: 30-day trial, then billed per asset in **Approved Inventory**.

EASM state	Meaning
Approved Inventory	Yours. Scanned daily. Billed
Candidate, Requires Investigation	Weak link to you. Review it
Dependency	Third-party infrastructure you rely on
Monitor Only	Related, not owned; kept separate for reporting

Defender for Servers: Plan 1 or Plan 2 3.2.6 3.2.7 4.1.5

Capability	Plan 1	Plan 2
Defender for Endpoint (EDR)	**Yes**	**Yes**
Vulnerability assessment	**Yes**	**Yes**, premium
Agentless scanning: vulnerabilities, secrets	No	**Yes**
Agentless malware scanning	No	**Yes**
File integrity monitoring	No	**Yes**, off until enabled
Just-in-time VM access	No	**Yes**
OS configuration assessment	No	**Yes**
Free ingestion: 500 MB a day per machine, pooled; eligible security tables; Plan 2 on the workspace	No	**Yes**

- Agentless scanning snapshots disks about **every 24 hours**, and only on **running** machines. Disks encrypted with customer-managed keys need Key Vault permissions first.
- Defender CSPM also includes agentless scanning for vulnerabilities and secrets.

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

Posture and monitoring

Collect only what detections and investigations need, keep it as long as the questions demand, and automate the routing.

SC-500 Academy posters
Back: Sentinel, Purview Audit and Security Copilot
Checked against Microsoft Learn on 20 October 2026

How data reaches Sentinel

4.2.4 4.2.5 4.2.6 4.2.7

Source → **Connector or Azure Monitor Agent** → **Data collection rule** filter, transform →

Table → **Analytics tier** rules, hunting → **Data lake** long retention

Source	Path	Lands in
Azure activity, Entra ID	Microsoft data connectors	AzureActivity, SigninLogs, AuditLogs
Defender XDR	On automatically when the workspace joins the Defender portal	Alerts, incidents, advanced hunting tables
Firewalls and appliances (CEF)	Syslog to a Linux forwarder with AMA	CommonSecurityLog
Linux syslog	AMA, syslog data collection rule	Syslog
Windows Security log	AMA; event set or custom XPath	SecurityEvent
Windows Event Forwarding	Collector with AMA, Forwarded Events	**WindowsEvent**
Anything else	Logs Ingestion API, DCR-based custom table	Name_CL

- The Defender XDR connector disconnects the per-product alert connectors itself and its alerts are free. Turn off Microsoft incident creation rules, or each alert raises two incidents.
- Windows machines outside Azure need **Azure Arc** before the Azure Monitor Agent.
- A connector that says Connected but shows no recent data is the failure to recognise. Check the Usage table.

Workspaces, roles and content

4.2.1 4.2.2 4.2.3

Role	Can
Microsoft Sentinel Reader	View data, incidents, workbooks
Microsoft Sentinel Responder	Also manage incidents
Microsoft Sentinel Contributor	Also create and edit content, such as analytics rules
Automation Contributor	For Sentinel itself: run playbooks
Playbook Operator	Run playbooks manually
Logic App Contributor	Build playbooks; no Sentinel role grants this

- One workspace unless a real reason splits it: data residency, separate tenants, billing.
- Sentinel in the Azure portal retires on **31 March 2027**; it lives in the Defender portal, with a primary workspace.
- **Content hub** solutions deliver templates. Nothing detects until you create rules from them.

Automation and retention

4.2.8 4.2.9

	Automation rule	Playbook
Is	Routing logic in Sentinel	A Logic App
Does	Assign, tag, change status, suppress until a date, run a playbook	Act in other systems
Needs	Sentinel Contributor	Automation Contributor for Sentinel + its own identity's roles

Retention	Detail
Analytics tier	30 days by default; Sentinel solution tables extend to 90 days at no charge, any table to two years. Rules and hunting see it
Data lake tier	Up to 12 years of total retention, at lower cost. Search jobs, KQL jobs, notebooks
Changing it	Shorter total retention: data kept 30 more days so you can revert. Analytics retention changes apply at once

Tables you should recognise

4.2.4 4.2.6 4.2.7

Table	Holds
SigninLogs, AuditLogs	Entra sign-ins and directory changes
AzureActivity	Azure control-plane operations
SecurityEvent	Windows Security events collected directly
WindowsEvent	Windows events forwarded through WEF
CommonSecurityLog	CEF from firewalls and appliances
Syslog	Linux and plain syslog
SecurityAlert, SecurityIncident	Alerts and incidents
Name_CL	Your custom tables
Usage	What was ingested, by table: the cost and health check

Sentinel in the Defender portal

4.2.1 4.2.2

- Onboarding sets a **primary workspace**; more workspaces can join. It needs Security Administrator in Entra ID, plus Owner (unconditional, at the subscription) or User Access Administrator with Microsoft Sentinel Contributor.
- The **Defender XDR connector** turns on automatically when the workspace joins.
- **GDAP with Azure Lighthouse** is not supported for Sentinel data in the Defender portal: use Entra B2B and Defender multitenant management. Lighthouse still lets advanced hunting query other tenants' workspaces with `workspace()`.
- Content hub installs need Microsoft Sentinel Contributor on the resource group.

Microsoft Purview Audit

4.2.10

	Standard	Premium
Licence	E3, E5 and others	E5 (Advanced Auditing service plan)
Default retention	180 days	1 year for Entra ID, Exchange, OneDrive, SharePoint
Longer retention	No	Retention policies; up to 10 years with an add-on
MailItemsAccessed	**Yes**	**Yes**, with sensitivity label
SearchQueryInitiated	No	**Yes**

- Search from the Defender portal Audit page or Purview: the same tool. Needs Audit Logs or View-Only Audit Logs.
- Nothing for every query? Check `UnifiedAuditLogIngestionEnabled`.

Cost controls

4.2.1 4.2.9

- Set a **daily cap** before the first connector. When reached, collection stops: security data too.
- Filter in the **data collection rule**: what the agent never collects is never billed (XPath for Windows events; facilities and severities for syslog). Transformation filtering is free only for Analytics tables in Sentinel workspaces.
- **Commitment tiers**: raising one restarts its 31-day period; lowering waits until the period ends, except within 6 hours of a change.
- Keep verbose tables short in the analytics tier and long in the data lake.

Microsoft Security Copilot

4.3.1 4.3.2 4.3.3 4.3.4

Capacity	Billing
Provisioned SCUs (1 to 100)	Hourly, from the moment provisioned
Overage SCUs	Only when used
Microsoft 365 E5 or E7	400 SCUs a month per 1,000 licences, up to 10,000; default capacity, not billed hourly

- Each **workspace** has its own capacity, plugins and role assignments. SCUs are not shared between workspaces.
- **Provisioning** needs Azure Owner or Contributor *and* Security Administrator.
- **Contributor** defaults to the Recommended Microsoft Security roles group. Everyone is the legacy default; once removed it cannot be re-added.
- Copilot answers with the user's own permissions. Plugins decide what it can reach; custom plugins are off for contributors by default.
- **Agents** run with an agent identity (recommended; Microsoft-built agents only) or a user account, and consume SCUs as they work.

Security Copilot roles

4.3.2 4.3.4

Role	Can
Copilot owner	Settings, plugins for everyone, capacity, roles
Copilot contributor	Use Copilot and their own plugins, within their own permissions

- Owner is inherited by Global Administrator, Security Administrator, Billing Administrator, Entra Compliance Administrator, Intune Administrator and some Purview roles.
- Copilot roles go to users or to **role-assignable** groups.
- Buying from the Security Store needs Owner or Contributor on the Azure billing subscription.

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

Operate it

Short portal paths and the command that does the same job. Full click paths are in each lab; check a command's syntax with Get-Help before you rely on it.

SC-500 Academy posters
Front: where things live, and how to build them
Checked against Microsoft Learn on 20 October 2026

Nine portals, and what SC-500 does in each

Portal	Address	SC-500 work there
Azure portal	portal.azure.com	Resources, Policy, RBAC, Key Vault, networking, Defender for Cloud
Microsoft Entra admin center	entra.microsoft.com	Conditional Access, authentication methods, PIM, apps and consent, Agent ID
Microsoft Defender portal	security.microsoft.com	Sentinel, incidents and blast radius, Security for AI, Audit search
Microsoft Purview portal	purview.microsoft.com	DSPM (was DSPM for AI), Audit, labels, DLP for Copilot
Microsoft 365 admin center	admin.microsoft.com	Agents: inventory, block, owners
SharePoint admin center	<tenant>-admin.sharepoint.com	Data access governance reports, RCD, RAC
Power Platform admin center	admin.powerplatform.microsoft.com	Threat detection for Copilot Studio, per environment
Microsoft Foundry portal	ai.azure.com	Guardrails, blocklists, AI gateway for the Foundry resource
Security Copilot	securitycopilot.microsoft.com	Workspaces, roles, plugins, agents, usage

Sentinel in the Azure portal retires on 31 March 2027. Learn its Defender portal paths.

Which PowerShell talks to what

Module	Covers	Connect with
Az	Everything in Azure Resource Manager, including Sentinel (Az.SecurityInsights)	`Connect-AzAccount`
Microsoft.Graph	Entra ID: users, apps, consent, Conditional Access, PIM	`Connect-MgGraph -Scopes ...`
ExchangeOnlineManagement	Audit configuration and audit search	`Connect-ExchangeOnline`
Microsoft.Online.SharePoint.PowerShell	Sites, RCD, RAC, data access governance	`Connect-SPOService`
Azure CLI	AKS and ACR settings, where the CLI is the documented route	`az login`

The AzureAD and MSOnline modules are retired. Commands below that start with Mg are Microsoft Graph PowerShell.

Identity

1.1.1 · 1.1.2 · 1.1.5 · 1.1.6

Task and portal path	PowerShell or CLI
Conditional Access policy Entra ID > Conditional Access	`New-MgIdentityConditionalAccessPolicy`
Authentication method Entra ID > Authentication methods > Policies	`Update-MgPolicyAuthenticationMethodPolicy AuthenticationMethodConfiguration`
PIM eligibility (Entra role) ID Governance > Privileged Identity Management	`New-MgRoleManagementDirectoryRoleEligibilityScheduleRequest`
PIM eligibility (Azure role) PIM > Azure resources	`New-AzRoleEligibilityScheduleRequest`
User consent settings Entra ID > Enterprise apps > Consent and permissions	`Update-MgPolicyAuthorizationPolicy`
Admin consent workflow Same blade, Admin consent settings	`Update-MgPolicyAdminConsentRequestPolicy`
User-assigned managed identity Managed Identities > Create	`New-AzUserAssignedIdentity`

Governance

1.3.1 · 1.3.4 · 1.3.5 · 4.1.3

Task and portal path	PowerShell or CLI
Assign a policy Policy > Assignments	`New-AzPolicyAssignment`
Fix existing resources Policy > Remediation	`Start-AzPolicyRemediation`
Exempt a resource Policy > Exemptions	`New-AzPolicyExemption`
Re-evaluate now No portal button: command, CLI or REST	`Start-AzPolicyComplianceScan`
Lock a resource Resource > Locks	`New-AzResourceLock -LockLevel ReadOnly`
Assign or define a role Access control (IAM)	`New-AzRoleAssignment` `New-AzRoleDefinition`
Turn a Defender plan on Defender for Cloud > Environment settings > Defender plans	`Set-AzSecurityPricing -PricingTier Standard`

No GA PowerShell route: use the portal

- Copilot Studio real-time protection: Defender portal and Power Platform admin center, both sides. Blocking rules: Settings, Security for AI, Policies & rules
- Agent management in the Microsoft 365 admin center (the Graph agent API is beta)
- Foundry guardrails and blocklists (or the REST API)
- Security Copilot roles, plugins and agents

A regulatory standard is a policy initiative, so `New-AzPolicyAssignment` can add one.

Data

1.2.1 · 1.2.4 · 2.1.1 · 2.2.1 · 2.2.2

Task and portal path	PowerShell or CLI
Key vault with purge protection Key vaults > Create	`New-AzKeyVault -EnablePurgeProtection`
Vault firewall Key vault > Networking	`Update-AzKeyVaultNetworkRuleSet -DefaultAction Deny`
Secret, key Key vault > Objects	`Set-AzKeyVaultSecret` `Add-AzKeyVaultKey`
Disable Shared Key, anonymous access Storage account > Configuration	`Set-AzStorageAccount -AllowSharedKeyAccess $false -AllowBlobPublicAccess $false`
Storage firewall Storage account > Networking	`Update-AzStorageAccountNetworkRuleSet -DefaultAction Deny`
Stored access policy Container > Access policy	`New-AzStorageContainerStoredAccessPolicy`
SQL: Entra admin, then Entra-only SQL server > Microsoft Entra ID	`Set-AzSqlServerActiveDirectoryAdministrator` `Enable-AzSqlServerActiveDirectoryOnlyAuthentication`
SQL auditing SQL server > Auditing	`Set-AzSqlServerAudit`

Network

2.3.1 · 2.3.2 · 2.3.6 · 2.3.8 · 2.3.9

Task and portal path	PowerShell or CLI

NSG rule, ASG
NSG > Inbound security rules
	`Add-AzNetworkSecurityRuleConfig`
	`Set-AzNetworkSecurityGroup`
	`New-AzApplicationSecurityGroup`

Security admin rule, then deploy Network manager > Configurations, Deployments	`New-AzNetworkManagerSecurityAdminRule` `Deploy-AzNetworkManagerCommit`
Private endpoint and DNS Resource > Networking > Private endpoint connections	`New-AzPrivateEndpoint` `New-AzPrivateDnsVirtualNetworkLink`
Firewall policy, threat intel deny Firewall Policy > Rule collections, Threat intelligence	`New-AzFirewallPolicy -ThreatIntelMode Deny` `New-AzFirewallPolicyRuleCollectionGroup`

Prove the path
Network Watcher > IP flow verify, Next hop
	`Test-AzNetworkWatcherIPFlow`
	`Get-AzNetworkWatcherNextHop`
	`Get-AzEffectiveNetworkSecurityGroup`

Compute and apps

3.2.1 · 3.2.2 · 3.2.3 · 3.2.8 · 3.3.2 · 3.3.3 · 3.3.7

Task and portal path	PowerShell or CLI
Trusted launch Create VM > Security type	`Set-AzVMSecurityProfile -SecurityType TrustedLaunch` `Set-AzVMUefi -EnableSecureBoot $true -EnableVtpm $true`
Encryption at host VM > Disks (VM deallocated)	`Update-AzVM -EncryptionAtHost $true`
Bastion VM > Connect > Bastion	`New-AzBastion`
Just-in-time access Defender for Cloud > Workload protections > Just-in-time VM access	`Set-AzJitNetworkAccessPolicy` `Start-AzJitNetworkAccessPolicy`
AKS: Entra only, admission control AKS > Security configuration, Policies	`az aks update --disable-local-accounts` `az aks enable-addons --addons azure-policy`
ACR: no shared credential Registry > Access keys	`az acr update --admin-enabled false`
App Service restrictions Web app > Networking > Access restriction	`Add-AzWebAppAccessRestrictionRule` `Update-AzWebAppAccessRestrictionConfig -ScmSiteUseMainSiteRestrictionConfig`

Monitoring and Microsoft 365

3.1.1 · 4.2.8 · 4.2.9 · 4.2.10

Task and portal path	PowerShell or CLI
Workspace daily cap Log Analytics workspace > Usage and estimated costs	`Set-AzOperationalInsightsWorkspace -DailyQuotaGb`
Table retention Defender portal > Microsoft Sentinel > Configuration > Tables	`Update-AzOperationalInsightsTable -TotalRetentionInDays`
Automation rule Microsoft Sentinel > Automation	`New-AzSentinelAutomationRule`
Audit on, and search On: Purview > Audit. Search: Purview or Defender portal > Audit	`Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled $true` `Search-UnifiedAuditLog`

RCD and RAC on a site
SharePoint admin center > Active sites (RAC: allow it for the tenant first)
	`Set-SPOSite -RestrictContentOrgWideSearch $true`
	`Set-SPOTenant -EnableRestrictedAccessControl $true`
	`Set-SPOSite -RestrictedAccessControl $true`

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

Operate it

The fastest way to stop each thing, and what that action leaves running. The right-hand column is where incidents get missed.

SC-500 Academy posters
Back: contain and clean up
Checked against Microsoft Learn on 20 October 2026

Identities and access

1.1.5 · 1.3.7 · 3.1.4 · 3.1.11

To stop	Do this	It does not stop
An app's access to your data	`Remove-MgOauth2PermissionGrant` `Remove-MgServicePrincipalAppRoleAssignment` Enterprise apps > app > Permissions	Users consenting again; access through Entra roles, Exchange RBAC or Teams RSC; tokens already issued
An app signing in at all	`Update-MgServicePrincipal -AccountEnabled:$false`	Tokens already issued, until they expire
A leaked app secret	`Remove-MgApplicationPassword`	Tokens already issued with it
An Azure role assignment	`Remove-AzRoleAssignment`	Other assignments (groups, parent scopes); up to 10 min to apply; managed identity tokens cached about 24 h
A PIM eligibility	PIM > Assignments > Remove	An activation already in progress may persist: check Active assignments
An autonomous agent	Conditional Access policy that blocks the agent identity	Tokens issued before the policy, until they expire; its blueprint creating new agent identities
An agent across the tenant	Microsoft 365 admin center > Agents > Block portal only	SharePoint and Foundry agents outside Copilot Chat; the agent identity's Entra permissions
A Security Copilot agent	Security Copilot > the agent > Pause portal only	

Network, compute and apps

3.2.3 · 3.3.2 · 3.3.3 · 3.3.8

To stop	Do this	It does not stop
An open management port	Remove the allow rule, or add a deny from Internet with a lower number; then JIT	Connections already open; Bastion (it connects from inside the network) unless a deny from Any outranks its allow
A running VM	`Stop-AzVM`	Disk charges, and data on its disks
The AKS admin credential path	`az aks update --disable-local-accounts` `az aks rotate-certs`	Entra users with Kubernetes roles. Without rotate-certs, admin kubeconfigs already downloaded keep working
The ACR admin password	`az acr update --admin-enabled false`	Repository-scoped tokens, anonymous pull if on, identities with pull or push roles
A WAF that only logs	WAF policy > Policy settings > Prevention	Attacks no rule matches

Data

1.2.5 · 2.1.1 · 2.1.4 · 2.2.1

To stop	Do this	It does not stop
A SAS with no stored access policy	`New-AzStorageAccountKey -KeyName key1`	SAS signed with the other key; user delegation SAS
A SAS bound to a stored access policy	`Remove-AzStorageContainerStoredAccessPolicy`	SAS signed directly with the account key
Every user delegation SAS	`Revoke-AzStorageAccountUserDelegationKeys`	Key-signed SAS
All key-based access	`Set-AzStorageAccount -AllowSharedKeyAccess $false`	Entra ID access with a data role, and user delegation SAS
Public reach to storage or SQL	`Set-AzStorageAccount -PublicNetworkAccess Disabled` `Set-AzSqlServer -PublicNetworkAccess Disabled`	Private endpoint paths; storage exceptions and resource instance rules already set
A leaked secret	`Update-AzKeyVaultSecret -Enable $false` then rotate it	A copy already read
SQL logins	`Enable-AzSqlServerActiveDirectoryOnlyAuthentication`	Entra users who hold database permissions

Clean up: the six places things are left behind

Bucket	Commonly left behind
Resources	The resource group, and anything created outside it. `Get-AzResource -TagName 'sc500-module'`
Subscription scope	Defender plans still billing; policy assignments; role assignments left orphaned by deleted identities
Directory scope	App registrations, service principals, Conditional Access policies, test users and groups
Soft-deleted remains	Key vault names held for the retention period; Log Analytics workspaces for 14 days
Access	Activated PIM roles: deactivate them
Verify	`Get-AzSecurityPricing` shows nothing on Standard you did not mean; next day's cost shows no new spend

From the Academy's teardown template, 00-03.

Beyond the exam: incident response

Not SC-500 objectives. Useful when the control above failed.

To stop	Do this
A compromised user's sessions	`Revoke-MgUserSignInSession`
The account itself	`Update-MgUser -AccountEnabled:$false`
A compromised device	Defender portal > device > Isolate device

Actions you cannot undo

1.2.2 · 1.3.8 · 4.3.2

- irreversible Turning on Key Vault **purge protection**.
- irreversible **Locking** an immutable Recovery Services vault, and **always-on** soft delete.
- irreversible Removing **Everyone** as Security Copilot contributor: it cannot be added back.
- irreversible **Purging** anything soft-deleted.
- **Lockout risk:** a Conditional Access policy with no break-glass exclusion; removing your standing admin role before proving PIM activation.

Deleted is not gone

1.2.2 · 1.3.8

Thing	Recoverable for
Key vault and its objects	7 to 90 days (soft delete). Purge protection blocks purging until then
Blobs and containers	Soft delete period you set
Log Analytics workspace	14 days. Same name, subscription, group and region brings it back; Sentinel does not come back
Entra users, Microsoft 365 groups, app registrations	30 days
Microsoft 365 agents	30 days
Backup data in a Recovery Services vault	14 days by default; enhanced soft delete longer

Prove it worked

Control	Check
Conditional Access	Sign-in logs > Conditional Access tab
Role assignments	`Get-AzRoleAssignment -Scope`
Policy	`Get-AzPolicyState`
Defender plans	`Get-AzSecurityPricing`
Key vault	`Get-AzKeyVault`
NSG and routing	`Get-AzEffectiveNetworkSecurityGroup`, `Get-AzNetworkWatcherNextHop`
AKS local accounts off	`az aks get-credentials --admin` must fail
Sentinel ingestion	Query the `Usage` table
Audit on	`Get-AdminAuditLogConfig`
RCD on a site	`Get-SPOSite` > RestrictContentOrgWideSearch

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.